OPÉRATION

Culot

Writeup d'investigation · phase en ligne

Démantèlement d'un faux fonds d'épargne « défense » : le Fonds Horizon Souverain 2035 et son fondateur autoproclamé.

ÉVÉNEMENT
CTF #BIG2026 · Opération Culot
Bpifrance · Hack'Olyte & Timios&Co

PÉRIODE (PHASE EN LIGNE)
2 au 8 octobre 2026

RÉDACTEURS
Équipe **Corvus Mind**
Mabimzaa · Shakado · Sirius · Noje_77

CLASSEMENT
3e au général (#BIG2026)

PÉRIMÈTRE DU DOCUMENT

Uniquement la **phase en ligne** (chapitre 1). La phase hybride du 8 octobre à l'Accor Arena fait l'objet d'un suivi séparé. Les flags et réponses exactes sont **masqués** ; seule la méthode est documentée.

SYNTHÈSE

1 Résumé de la phase en ligne

> La phase en ligne n'était pas une série d'énigmes isolées : c'était **une seule enquête.** À partir d'un débunk de fact-checking, on remonte un faux fonds d'épargne « défense », le **Fonds Horizon Souverain 2035** (sigle HSOV), jusqu'à son fondateur autoproclamé et la structure pyramidale cachée derrière une façade patriotique.

Le scénario joue sur un leurre crédible : un placement « souverain » promettant **13 % garantis dès 150 €**, estampillé d'un faux « Certifié conforme » et d'un logo Bpifrance détourné. Chaque challenge ajoute une pièce : l'association qui débunke, la technique de manipulation employée, l'auteur du site, le vrai fonds imité, puis l'identité derrière le masque.

Le fil rouge est toujours le même : **partir d'un détail public, le recouper, éliminer les fausses pistes.** Les métadonnées d'un PDF généré côté client, un pseudonyme réutilisé de plateforme en plateforme, un EP sorti sur Spotify : autant de traces laissées par le personnage, qui finissent par se recouper.

CE QU'ON A EXPLOITÉ

Fact-checking LinkedIn, code source du site, propriétés d'un PDF jsPDF, registres d'entreprises (Pappers), réseaux sociaux (Instagram, Truth Social), Telegram, Spotify, explorateur blockchain.

CE QU'ON N'A PAS FAIT

Aucune action intrusive, aucun script automatisé, aucune réinitialisation de compte, aucune ingénierie sociale. Uniquement de la lecture de sources publiques, conformément au règlement.

CONTEXTE

2 Le scénario

Thème de l'édition : **« Le Culot »**. Le décor est un faux produit financier qui se fait passer pour un placement patriotique adossé à la défense française.

- **Le produit :** Fonds Horizon Souverain 2035 (sigle `HSOV`), slogan « Construire aujourd'hui une France plus forte demain », « 13 % bruts minimum calculé sur 3 ans », accessible dès 150 €.
- **La façade :** un site vitrine, une page LinkedIn d'entreprise, une mention « ✅ Certifié conforme » sans organisme cité, un logo Bpifrance détourné.
- **Le vrai modèle imité :** le véritable fonds de défense de Bpifrance (à partir de 500 €, objectif non garanti, blocage 5 ans, perte en capital possible). Tout l'inverse des promesses du faux.
- **Le piège caché :** derrière la vitrine, une mécanique de paliers (Profane, Apprenti, Compagnon, Maître, Cercle suprême) conditionnée à des filleuls et à un jeton interne. Une structure **pyramidale** classique maquillée en « cercle privé ».

> **Clé de lecture :** chaque élément de façade est une porte. Le « Certifié conforme » invite à chercher qui certifie (personne). Le logo Bpifrance invite à comparer au vrai fonds. Le « cercle privé » invite à chercher la structure pyramidale. L'enquête consiste à pousser chaque porte.

CHEMINEMENT

3 Méthode & sources exploitées

FACT-CHECKING	Association de vérification d'informations qui circule sur LinkedIn. Son **débunk daté** du faux fonds (noté « Trompeur ») est le point d'entrée de toute l'enquête.
SITE WEB	Site vitrine du faux fonds (pages vision, candidature, mentions légales). **Code source** lu directement : c'est là que se cache l'indice décisif, pas dans les images ni le WHOIS.
DOC / PDF	PDF « Profil d'investisseur » **généré côté client** (jsPDF). Ses propriétés (author / creator / keywords) portent le pseudonyme de l'auteur. Autres PDF du bot : analyse de structure et de métadonnées (C2PA).
REGISTRES	Base entreprises (Pappers) pour le **vrai** fonds imité : forme juridique, date, siège, SIREN. À distinguer de la société de gestion.
RÉSEAUX SOCIAUX	Un même pseudonyme réapparaît sur **Instagram, Truth Social et Spotify**. Le nom affiché, les bios et les renvois d'un réseau à l'autre tracent le personnage.
MESSAGERIE	Bot Telegram « assistant privé » : référence de dossier générée côté client, menu Paliers / Parrainage / Documents, et un « Protocole de Récupération » (phrase de 24 mots) laissé pour plus tard.
PRESSE	Articles de presse économique (oct. 2025) sur le vrai fonds, et cadre officiel listant les emplois des obligations défense.
BLOCKCHAIN	Explorateur de testnet pour le jeton interne (conversion annoncée depuis l'ETH) et une adresse de fuite à surveiller.

> **Principe de soumission :** tentatives limitées, 2 par minute. On se concerte avant chaque envoi. Une mauvaise réponse ne coûte rien, sauf essais limités : on ne soumet jamais « au feeling ».

LE CŒUR

4 Déroulé par challenge

0 Démarrage

RÈGLEMENT

OBJECTIF	Trouver la phrase d'amorçage.
DÉMARCHE	La phrase est écrite **dans le règlement**. L'exemple de format fourni n'est qu'un modèle, pas la réponse.
PIÈGE	Recopier l'exemple de format au lieu de la vraie phrase.
FLAG	masqué

1 Comment jouer ?

NARRATION · 25

OBJECTIF	Accepter les règles du jeu.
DÉMARCHE	La phrase d'acceptation figure dans la page « Comment jouer ? ».
ATTENTION	Valider cette étape **lance le chrono de l'équipe** (départage à égalité de points). À ne faire qu'une fois prêts.
FLAG	masqué

2 Le débunk de l'asso

NARRATION

OBJECTIF	Retrouver l'article de débunk du faux fonds.
DÉMARCHE	L'énoncé reprend **mot pour mot** l'auto-description d'une association de fact-checking qui vérifie les infos circulant sur LinkedIn. On identifie l'asso, puis on cherche sur son site le débunk daté du fonds (noté « Trompeur »).
PIVOTS	Le débunk ouvre la suite : post LinkedIn d'origine, page entreprise, mention « Certifié conforme » sans organisme, logo Bpifrance détourné.
FLAG	URL du débunk · masquée

3 Le prodrome

FACILE · 50

OBJECTIF	Rattacher le FOMO créé par « NOMBRE DE PLACES LIMITÉES » à une phase d'un référentiel de manipulation de l'information.
DÉMARCHE	Le référentiel (matrice DIMA du M82 Project) a 4 phases. Le FOMO / biais de rareté est une technique rangée dans une tactique de « valorisation individuelle », rattachée à l'une de ces phases. On la retrouve dans la galerie de techniques publiée.
FORMAT	Un verbe à l'infinitif (modèle fourni par l'énoncé).
FLAG	masqué

4 Le diable se cache dans les détails

MOYEN · 100

OBJECTIF Le pseudonyme de l'auteur du site.

DÉMARCHE Les pistes évidentes sont stériles (voir Pièges). L'indice est dans le **code source** : la page de candidature génère un PDF « Profil d'investisseur » via **jsPDF**, et l'appel doc.setProperties renseigne **author, creator et keywords** avec un pseudonyme unique.

PIÈGES WHOIS masqué (registrar seulement), aucune métadonnée dans les images, pas de robots.txt ni sitemap, mentions légales à adresse fictive. Tout ça est volontaire pour faire perdre du temps.

FLAG `pseudonyme · masqué` (réutilisé ensuite sur Instagram, Truth Social et Spotify)

5 Le vrai fonds

SIREN

OBJECTIF Le SIREN du vrai fonds imité (fonds professionnel spécialisé constitué en société de libre partenariat, immatriculé au RCS de Créteil).

DÉMARCHE Identifier le véritable fonds de défense de Bpifrance (créé le 1er octobre 2025), puis lire sa fiche sur une base d'entreprises (Pappers) pour son SIREN.

PIÈGE La plaquette commerciale affiche « 433 975 224 RCS Créteil » : c'est le SIREN de la **société de gestion**, pas du fonds. Ne pas confondre le gérant et le véhicule.

FLAG `SIREN du fonds · masqué`

6 Article des Échos

CITATION · à finaliser

OBJECTIF Recopier mot pour mot la phrase de l'article qui liste les financements rendus possibles par les obligations défense.

DÉMARCHE Repérer le bon article (presse éco, oct. 2025). Le cadre officiel Bpifrance liste les emplois des fonds levés (prêts aux PME de la BITD, aux groupements spécialisés, à l'export européen, diagnostics cyber défense) : la phrase recherchée reprend cette énumération.

PIÈGE Paywall : l'article doit être ouvert à la main. Respecter la **ponctuation et les accents exacts** (format de flag).

FLAG `phrase exacte · masquée`

7 Identité de l'auteur

PRÉNOM NOM · amorcé en ligne

OBJECTIF La véritable identité derrière le pseudonyme.

DÉMARCHE Pivot par pseudonyme réutilisé : **Instagram** (nom affiché stylisé, bio qui renvoie vers « le réseau de la vérité »), **Truth Social** (« BBKM Invest Academy », annonce d'un passage à BIG, « on me connaît pour la musique »), puis **Spotify** (artiste du même nom, EP « Le Cercle des Deux Mondes », label identique, featuring « Dídymi Mou » = « mon jumeau » en grec).

FORMAT Prénom Nom.

STATUT La résolution complète du nom civil s'est faite sur la phase hybride (hors périmètre). En ligne, on tenait déjà la piste musicale et la structure pyramidale.

FLAG `masqué`

La phase en ligne comptait d'autres étapes de narration et de progression autour de la même enquête (bot Telegram, paliers, jeton HSOV). Elles ne sont pas détaillées ici une par une : la logique est toujours celle décrite ci-dessus.

CARTOGRAPHIE

5 Acteurs, entités & infrastructure

Le personnage

Fondateur autoproclamé du fonds, présent sous le **même pseudonyme** sur Instagram, Truth Social et Spotify. Se revendique musicien et investisseur. Nom de label récurrent qui relie tous ses comptes.

La façade « fonds »

Fonds Horizon Souverain 2035 (HSOV) : site vitrine, page LinkedIn d'entreprise, faux « certifié conforme », logo Bpifrance détourné. Promesse de rendement garanti irréaliste.

La mécanique cachée

Paliers Profane → Cercle suprême, conditionnés à un nombre de filleuls et à un jeton interne (HSOV). Un retrait remet la progression à zéro : **schéma pyramidal** typique, maquillé en cercle privé.

Le vrai fonds (référence)

Fonds de défense réel de Bpifrance, créé fin 2025. Sert de modèle imité par le faux. C'est en le retrouvant en registre qu'on distingue le fonds de sa société de gestion.

Infrastructure & traces techniques

- **Web :** WHOIS anonymisé, aucune métadonnée image, pas de robots.txt ni sitemap. L'unique faille laissée volontairement est la génération de PDF côté client (jsPDF) et ses propriétés.
- **Messagerie :** bot Telegram « assistant privé » ; référence de dossier générée côté client ; menu Documents / Paliers / Parrainage ; « Protocole de Récupération » réclamant une phrase de 24 mots (laissée pour une étape ultérieure).
- **Documents :** PDF de paliers et carrousel ; métadonnées C2PA indiquant une génération par IA, rien d'identifiant ; un faux logo « bpifrance.io » en dernière page.
- **Blockchain :** jeton interne HSOV annoncé en conversion depuis l'ETH ; une adresse de fuite à surveiller (fonds jamais ressortis).

RETOUR D'EXPÉRIENCE

6 Pièges & leçons

LES FAUSSES PISTES

- WHOIS anonymisé : volontaire, rien à en tirer.
- Métadonnées d'images : vides, c'est un leurre.
- Adresse des mentions légales : fictive, assumée.
- SIREN de la plaquette : celui du gérant, pas du fonds.
- Un admin a signalé un lien « exiftool » comme fausse piste : à ignorer.

CE QU'ON RETIENT

- Lire le **code source** avant de s'épuiser sur les métadonnées.
- Un **pseudo réutilisé** est le meilleur pont entre comptes.
- Distinguer une entité de sa **société de gestion** en registre.
- L'**exemple de format** n'est jamais la réponse.
- Respecter accents et ponctuation : le format de flag est strict.

Discipline d'équipe : tentatives limitées et concertation avant chaque soumission. Un membre ouvre les sources derrière paywall / vérification humaine (presse, captchas) ; les autres recoupent en parallèle. On ne soumet que sur preuve.

BILAN

7 Conclusion

La phase en ligne d'Opération Culot est un bel exercice de **désinformation financière** : un faux placement patriotique, une structure pyramidale déguisée, et un personnage qui sème ses traces sur une demi-douzaine de plateformes. Rien ne se pirate ; tout se lit, se recoupe et se date.

Corvus Mind termine **3e au classement général** de l'édition #BIG2026. La phase en ligne documentée ici a porté l'équipe en tête du provisoire ; les quelques étapes laissées ouvertes se sont refermées sur la phase hybride, documentée à part.

> **Writeup méthode.** Les flags et réponses exactes sont masqués : aucune solution n'est divulguée, seule la démarche est documentée. Pensez à vérifier les conditions de l'organisateur avant toute rediffusion.

© 2026 Corvus Mind